Designing a Secure National Government API Infrastructure (SNGAPI) for Digital Public Services in Sri Lanka - A Governance-Driven and Education-Integrated Digital Public Infrastructure Model

Jehan Weerasuriya
Independent Researcher
Sri Lanka
2026
jehankandy@gmail.com

Abstract

Sri Lanka's public digital service ecosystem remains institutionally fragmented, characterized by isolated government systems lacking unified API governance, federated authentication, standardized authorization control, and enforceable interoperability policies. This fragmentation limits secure inter-ministerial communication, increases administrative risk, and constrains scalable digital transformation.

This technical report proposes the Secure National Government API Infrastructure (SNGAPI), a governance-driven national API ecosystem designed to unify digital public services under a centralized Zero Trust–aligned architecture. The framework integrates OAuth 2.0 and OpenID Connect–based federated identity management, Policy-Based Access Control (PBAC), hybrid authorization with fine-grained administrative override governance, tiered API access enforcement, and immutable audit logging aligned with Sri Lanka's Personal Data Protection Act No. 9 of 2022.

Drawing from validated prior research on adaptive middleware security and administrative misuse mitigation, SNGAPI extends these models into a sovereign Digital Public Infrastructure (DPI) framework. Additionally, the architecture introduces a regulated educational sandbox layer that embeds production-mirrored API environments into university curricula to address systemic graduate skill mismatch.

SNGAPI is positioned not merely as a technical gateway, but as a national digital governance blueprint integrating security architecture, policy enforcement, interoperability standards, and education-sector participation within a sustainable and scalable digital public infrastructure model.

Keywords: Digital Public Infrastructure; API Governance; National API Gateway; Zero Trust Architecture; Policy-Based Access Control; OAuth 2.0; OpenID Connect; Government Interoperability; Administrative Override Governance; Educational Sandbox Architecture; Sri Lanka Digital Transformation; Middleware Security Architecture

Executive Summary

Sri Lanka's digital public service ecosystem is structurally fragmented, characterized by institutionally isolated systems lacking unified API governance, centralized authentication federation, policy-based authorization enforcement, and cross-agency interoperability.

This technical report proposes the **Secure National Government API Infrastructure (SNGAPI)** — a governance-driven national API ecosystem designed to unify digital public services under a centralized, security-first architectural framework aligned with:

- Zero Trust Architecture principles [5]
- OAuth 2.0 Authorization Framework [6]
- OpenID Connect Identity Federation [7]
- Estonia's X-Road interoperability model [8], [9]
- Singapore Digital Government practices [10]
- Sri Lanka's Personal Data Protection Act No. 9 of 2022 [11]

SNGAPI integrates three prior architectural research contributions [1]–[4] into a scalable national Digital Public Infrastructure (DPI) framework that combines:

- Adaptive middleware orchestration
- Policy-Based Access Control (PBAC)
- Hybrid authorization with fine-grained administrative override governance
- Federated identity architecture

- Tiered access enforcement
- Educational sandbox integration

SNGAPI is positioned not merely as a technical gateway, but as a sovereign digital governance blueprint for Sri Lanka.

1. Introduction

Sri Lanka is undergoing progressive digital transformation across ministries, regulatory authorities, higher education institutions, and financial systems. However, most systems have been developed independently, resulting in:

- API silos
- Redundant identity mechanisms
- Inconsistent security enforcement
- Weak cross-agency audit transparency
- Limited interoperability

Global digital governments treat interoperability as infrastructure. Estonia's X-Road [8], [9] and Singapore's Digital Government architecture [10] demonstrate that national API ecosystems must be centrally governed rather than organically accumulated.

Sri Lanka currently lacks:

- A National API Registry
- Centralized API lifecycle governance
- Federated authentication framework
- Unified policy-based authorization
- Structured academic sandbox integration

This report proposes SNGAPI to address these structural gaps.

2. Research Continuity and Architectural Foundations

SNGAPI builds upon prior validated architectural research.

2.1 Security-First Backend Framework (PBAC Foundation)

The framework introduced in [1] established:

- Adaptive middleware orchestration
- Policy-Based Access Control (PBAC)
- Context-aware routing
- Dynamic enforcement layers

Within SNGAPI, this model forms the core policy enforcement engine at the national API gateway.

2.2 Hybrid Authorization Model

The hybrid authorization model proposed in [2] and validated in [3] mitigates administrative privilege abuse through:

- Password-less authentication
- Fine-grained override governance
- Immutable override logging
- Multi-layer approval mechanisms

Within SNGAPI, this becomes the national override governance control layer.

2.3 Educational Skill Mismatch Research

Research in [4] identified structural graduate skill mismatch caused by:

- Examination-dominant assessment
- Limited exposure to production systems
- Minimal applied system integration

SNGAPI introduces controlled API sandbox environments to operationalize Digital Public Infrastructure as a national applied learning ecosystem.

3. Global Standards and Legal Alignment

3.1 Zero Trust Architecture (NIST SP 800-207)

SNGAPI adopts Zero Trust principles [5]:

- Continuous identity verification
- No implicit trust based on network position
- Policy-driven dynamic access decisions
- Full visibility and logging

Every API call is authenticated and authorized independently.

3.2 OAuth 2.0 and OpenID Connect

SNGAPI aligns with:

- OAuth 2.0 (RFC 6749) [6]
- OpenID Connect Core 1.0 [7]

Authorization uses:

- Short-lived access tokens
- Scoped permissions
- JWT identity claims
- Refresh token governance

3.3 Legal Compliance – PDPA 2022

Sri Lanka's Personal Data Protection Act No. 9 of 2022 [11] mandates:

- Purpose limitation
- Data minimization
- Access traceability
- Accountability

SNGAPI enforces PDPA compliance through:

- Scoped token-based data access
- Immutable audit logging
- Centralized monitoring
- Policy-bound resource exposure

4. System Architecture and Enforcement Model

SNGAPI consists of six integrated layers:

1. Governance Layer
2. Identity and Authentication Layer
3. Authorization and PBAC Layer
4. API Gateway and Resource Management Layer
5. Security Monitoring Layer
6. Educational Integration Layer

4.1 Governance Layer

The Governance Layer proposes a National API Authority (NAA) responsible for:

Function	Enforcement Mechanism
API registration	Mandatory gateway onboarding
Version control	Semantic versioning enforcement
Security certification	Pre-deployment audit
Logging mandates	Central audit vault
Interoperability rules	Cross-ministry compliance checks

Table 1: National API Authority (NAA)

API Lifecycle Flow

1. Proposal submission
2. Security review
3. Schema validation
4. PDPA compliance verification
5. Gateway registration
6. Monitoring activation
7. Periodic audit

4.2 Identity and Authentication Layer

Authentication flow (OAuth Authorization Code Model):

1. User authentication via Identity Provider
2. Authorization code issued
3. Token exchange at gateway
4. Access token validation
5. API request processing

Token Types

Token	Purpose	Lifetime
Access Token	API access	Short
Refresh Token	Session renewal	Medium
ID Token	Identity assertion	Short
Override Token	Admin override	Single-use

Table 2: token types

Override tokens require:

- Justification
- Multi-party approval
- Audit signature
- Immutable log binding

4.3 Authorization and PBAC Layer

Policy-Based Access Control evaluates:

Attribute Type	Examples
Subject	Role, clearance
Resource	API classification
Action	Read/Write/Override
Context	Time, IP, anomaly score

Table 3: Policy-Based Access Control

Policy Decision Flow

1. Token validation
2. Attribute extraction
3. Rule evaluation
4. Risk scoring
5. Access decision

Risk Escalation Model

Risk Level	Trigger	Response
Low	Normal access	Log
Medium	Context anomaly	Extra verification
High	Override attempt	Multi-party approval
Critical	Abuse pattern	Account suspension

Table 4: Risk Escalation Model

4.4 API Gateway and Resource Management

Gateway responsibilities:

- Central routing
- Rate limiting
- Quota enforcement
- Traffic anomaly detection
- Token validation

Tiered Access Model

Tier	Users	Rate Limit	Audit Level
Public	Citizens	Low	Basic
Academic	Verified universities	Medium	Enhanced
Institutional	Enterprises	High	Full
Government Core	Ministries	Dedicated	Continuous

Table 5: Tiered Access Model

Dynamic rate adaptation adjusts quotas based on risk scores.

4.5 Security Monitoring Layer

Aligned with Zero Trust [5].

Threat Mitigation Mapping

Threat	Mitigation
Credential theft	Password-less tokens
Insider abuse	Override governance
API scraping	Rate limiting
Data exfiltration	Scoped tokens
Privilege escalation	PBAC enforcement

Table 6: Threat Mitigation Mapping

4.6 Educational Sandbox Layer

To address graduate skill mismatch [4]:

Feature	Production	Sandbox
Real Data	Yes	Synthetic
Rate Limits	SLA	Controlled
Override	Restricted	Disabled
Logging	Full	Full

Table 7: Educational Sandbox Layer

Academic Access Flow

1. Institutional verification
2. Domain-based identity federation
3. Sandbox-only scoped token issuance
4. Continuous monitoring

This enables safe real-world system integration training.

5. Implementation Roadmap

Phase 1 – Core Infrastructure

- API registry
- Gateway deployment
- OAuth federation

Phase 2 – Policy Enforcement

- PBAC engine
- Override governance
- Audit vault deployment

Phase 3 – Compliance Integration

- PDPA enforcement mapping
- Monitoring expansion

Phase 4 – Academic Onboarding

- Sandbox launch
- University collaboration

Phase 5 – Nationwide Federation

- Cross-ministry integration
- SLA enforcement
- Developer ecosystem expansion

6. National Impact

SNGAPI enables:

- Secure inter-ministerial communication
- Infrastructure cost reduction
- PDPA-aligned digital governance
- GovTech innovation pipeline
- Graduate employability improvement
- Sovereign digital infrastructure control

7. Limitations

- Requires political commitment
- High initial infrastructure cost
- Institutional resistance risk
- Legislative support required

8. Conclusion

SNGAPI establishes a governance-driven Digital Public Infrastructure model that integrates:

- Zero Trust security principles
- OAuth and OpenID identity federation
- Policy-based access control
- Hybrid authorization governance
- Educational integration
- PDPA legal compliance

Rather than functioning as a standalone API gateway, SNGAPI represents a national digital governance architecture aligning security, interoperability, policy enforcement, and education under a unified sovereign framework.

References:

[1] *J. Weerasuriya, "A Security-First Backend Framework with Adaptive Middleware Flow and Policy-Based Access Control for Enterprise Applications,"*

Available: https://www.researchgate.net/publication/400252379_A_Security-First_Backend_Framework_with_Adaptive_Middleware_Flow_and_Policy-Based_Access_Control_for_Enterprise_Applications

[2] *J. Weerasuriya, "A Hybrid Authorization Model for Mitigating Administrative Misuse Using Password-less Authentication and Fine-Grained Overrides,"*

Available: https://www.researchgate.net/publication/400279940_A_Hybrid_Authorization_Model_for_Mitigating_Administrative_Misuse_Using_Password-less_Authentication_and_Fine-Grained_Overrides

[3] *J. Weerasuriya, "Prototype Implementation and Validation of a Hybrid Authorization Model for Mitigating Administrative Misuse Using Password-less Authentication and Fine-Grained Overrides,"*

Available: https://www.researchgate.net/publication/400396181_Prototype_Implementation_and_Validation_of_a_Hybrid_Authorization_Model_for_Mitigating_Administrative_Misuse_Using_Password-less_Authentication_and_Fine-Grained_Overrides

[4] *J. Weerasuriya, "Exam-Oriented Education and Graduate Skill Mismatch in Sri Lanka,"*

Available: https://www.researchgate.net/publication/400818609_Exam-Oriented_Education_and_Graduate_Skill_Mismatch_in_Sri_Lanka

[5] *S. Rose, O. Borchert, S. Mitchell, and S. Connelly*, Zero Trust Architecture, *NIST Special Publication 800-207, Aug. 2020.*
Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf

[6] *D. Hardt, "The OAuth 2.0 Authorization Framework," IETF RFC 6749, Oct. 2012.*
Available: https://www.rfc-editor.org/rfc/rfc6749

[7] *OpenID Foundation, "OpenID Connect Core 1.0," 2014.*
Available: https://openid.net/specs/openid-connect-core-1_0.html

[8] *Government of Estonia, "X-Road – Interoperability Services," e-Estonia.*
Available: https://e-estonia.com/solutions/interoperability-services/x-road/

[9] *Nordic Institute for Interoperability Solutions (NIIS), "X-Road® Technology Overview."*
Available: https://x-road.global/x-road-technology-overview/

[10] *Digital Government Singapore, "Digital Government Resources."*
Available: https://www.digitalgateway.gov.sg/our-resources/digital-government/

[11] *Parliament of Sri Lanka,* Personal Data Protection Act, No. 9 of 2022*, Colombo, Sri Lanka, 2022.*
Available: https://www.parliament.lk/uploads/acts/gbills/english/6332.pdf

[12] *J. Weerasuriya, "Designing a Secure National Government API Infrastructure (SNGAPI) for Digital Public Services in Sri Lanka," ResearchGate.*

Available:
https://www.researchgate.net/publication/400857148_Designing_a_Secure_National_Government_API_Infrastructure_SNGAPI_for_Digital_Public_Services_in_Sri_Lanka